

ANÁLISIS: APLICANDO EL MÉTODO CIENTÍFICO EN LA INVESTIGACIÓN DIGITAL

- Cuando un investigador forense empieza a indagar en el caso, este evaluará las evidencias y llegará a varias sospechas de lo que ha sucedido.
- Estas sospechas son básicamente **hipótesis** del caso.
- Este tipo de enfoque de investigación debe ser llevado a cabo de manera controlada para que el investigador no se pierda en todas las posibles hipótesis distintas que pueden llegar a plantearse.
- Para esto se utiliza un **método científico de investigación** y un **modelo de proceso forense**
 - 1- Recolección
 - 2- Examinación/Extracción.
 - 3- Análisis.
 - 4- Reporte.

ANÁLISIS: APLICANDO EL MÉTODO CIENTÍFICO EN LA INVESTIGACIÓN DIGITAL

- En la práctica, los investigadores digitales son más eficientes con metodologías más simples que los guían en la dirección correcta, mientras les permite mantener la flexibilidad para manejar diversas situaciones.
- El **método científico** proporciona una metodología sencilla y flexible.
- Comienza con la compilación de datos y validación, procede a la formación de hipótesis y experimentación/pruebas, buscando activamente evidencia que refute la hipótesis, revisando conclusiones cada vez que emergen nuevas evidencias.

ANÁLISIS: DESAFÍOS Y ENFOQUE

- Los investigadores enfrentan desafíos a lo largo de una investigación que tienen que descifrar a través de la aplicación de su experiencia e intuición para formular teorías, y evaluar estas teorías según la información disponible.
- El **enfoque basado en hipótesis** de las investigaciones forenses digitales proporciona un modelo inicial que une prácticas de investigación digital y la teoría de la ciencias de la computación, destacando el papel del método científico dentro de una investigación digital.

ANÁLISIS: PASOS

- Los siguientes 5 pasos pueden guiar al investigador digital a través de casi cualquier situación investigaría:
 1. Observación
 2. Hipótesis
 3. Predicción
 4. Experimentación/Prueba
 5. Conclusión

ANÁLISIS: 1. OBSERVACIÓN

- Uno o más eventos ocurrirán e iniciarán nuestra investigación.
- Estos eventos incluirán varias observaciones que serán los hechos iniciales del incidente.
- Los investigadores digitales procederán a partir de estos hechos para formar su investigación.
- **Ej de eventos:**
 - La computadora dejó de funcionar
 - Mucho tráfico de red.
 - Servidor super lento.
 - Ransomware
 - Datos brindados por los responsables

ANÁLISIS: 2. HIPÓTESIS

- Basado en los hechos actuales del incidente, los investigadores digitales formarán una teoría de lo que pueda haber ocurrido.
- **Ejemplo:**
 - **La computadora dejó de funcionar:** algún tipo de malware
 - **Mucho tráfico de red:** Puede ser un bruteforce al ssh o una exfiltración masiva
 - **Servidor super lento:** ataque de DoS
 - **Ransomware:** puede ser una vulnerabilidad del sistema o un usuario inexperto
 - **Datos brindados por los responsables:** data cronológica útil.

ANÁLISIS: 3. PREDICCIÓN

- Basándose en la hipótesis, los investigadores digitales podrán predecir dónde pueden estar ubicados los artefactos relacionados con un evento.
- **Ejemplo:**
 - **Algún tipo de malware:** buscar descargas, home's de usuarios, timeline por archivos modificados.
 - **Puede ser un bruteforce al ssh:** Buscar en logs de autenticación, modificación de archivos ssh. Recordar la clase pasada.
 - **Ataque de DoS::** Buscar en logs de acceso si es web, logs de aplicaciones.

ANÁLISIS: 4. EXPERIMENTACIÓN/PRUEBA

- Los investigadores digitales podrán entonces analizar la evidencia disponible para probar la hipótesis, buscando por la presencia de artefactos predichos anteriormente.
- Parte del método científico es también poner a prueba posibles explicaciones alternativas.
 - Si la hipótesis original es correcta un investigador digital será capaz de eliminar explicaciones alternativas a partir de la evidencia disponible.
- **Ejemplo:** Se revisan los logs, si no se encuentra nada, se puede decir que **"el atacante no ingresó via SSH"** o se puede plantear una nueva hipótesis que **"el atacante borró los logs"**

ANÁLISIS: 5. CONCLUSIÓN

- Los investigadores digitales formarán una conclusión basada en los resultados de sus hallazgos.
- Un investigador digital puede haber encontrado que la evidencia apoya la hipótesis, falsifica la hipótesis, o que no había suficientes hallazgos para generar una conclusión.
- **Ejemplo:**
 - Se encontró evidencia de un ataque bruteforce exitoso en los logs.
 - No se encontro evidencia de ataque bruteforce ya que los logs fueron borrados, pero se estima que el ataque fue realizado en tal dia.

ANÁLISIS: REPETICIÓN

- Esta metodología general puede ser repetida tantas veces como sea necesario para alcanzar conclusiones en cualquier fase de la investigación digital.

ANÁLISIS: INTRUSIONES A COMPUTADORAS

- Los criminales entran en computadoras por una gran variedad de propósitos, incluyendo:
 - Robar información valiosa
 - Espiar conversaciones de los usuarios
 - Acosar usuarios
 - Lanzar ataques hacia otros sistemas
 - etc

ANÁLISIS: ENTENDIENDO AL ATACANTE

- Nuevas maneras de interferir y vulnerar sistemas son creadas todos los días con distintos niveles de sofisticación.
- Aunque se necesita cierto nivel de conocimiento para implementar estos ataques, una vez que el nuevo método existe se publica o se vende en Internet.
- Los programas que automáticamente explotan una vulnerabilidad son comúnmente llamados '**exploits**' y muchos de ellos son fácil de encontrar en internet junto a las instrucciones para **explotar** sistemas.
- Con muy poco de conocimiento de redes de computadoras, casi cualquier persona puede obtener y utilizar las herramientas necesarias para ser una molestia, o incluso peligroso.

ANÁLISIS: METODOLOGÍA BÁSICA DEL ATACANTE

- Aunque existen muchas y variadas maneras de ataques, técnicas, tácticas y procedimientos que se pueden utilizar para comprometer un sistema, podemos abstraer una descripción de 4 pasos:

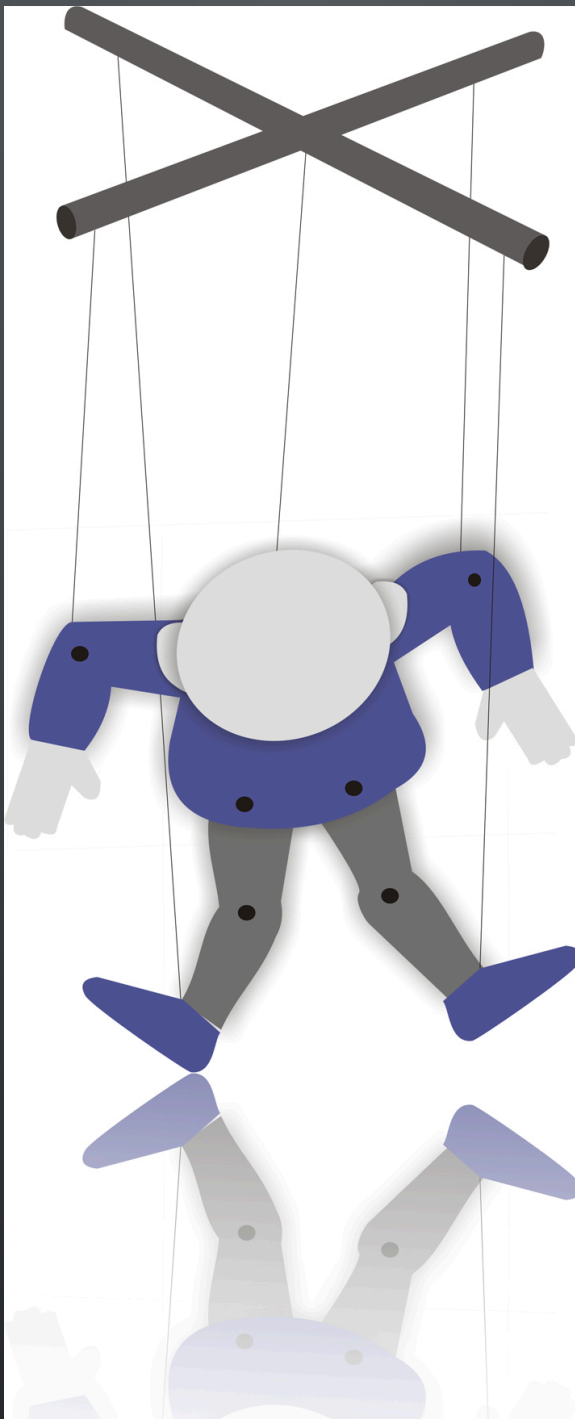
ANÁLISIS: METODOLOGÍA BÁSICA DEL ATACANTE

1. **Reconocimiento:** Es el proceso de obtener información del objetivo que pueda ser útil para saber que, como atacar y el mejor momento para hacerlo.
2. **Atacar:** Es el proceso de aplicar una técnica contra el sistema objetivo que, si es efectivo, podría resultar en el acceso no autorizado o una denegación de servicio.
3. **Persistencia:** Es el proceso de asegurar el continuo y secreto acceso administrativo a los sistemas objetivo.
4. **Abuso:** Es el proceso de llevar a cabo cualquier otra actividad sobre objetivos comprometidos que cumplan con los fines del atacante.

ANÁLISIS: METODOLOGÍA BÁSICA DEL ATACANTE

- Lograr la **persistencia** puede implicar la instalación de **backdoors**, **rootkits** y otros programas maliciosos para permitir acceso continuo y permanente.
- Es importante entender que estos 4 pasos no necesariamente se realizarán en orden, pueden ser repetidos o mezclados muchas veces durante la intrusión para realizar objetivos específicos.
- Un ejemplo clásico es el de las redes botnets, donde cada equipo comprometido queda "esperando" por "órdenes" del cerebro de la red para empezar a funcionar, por caso, a enviar Spam.

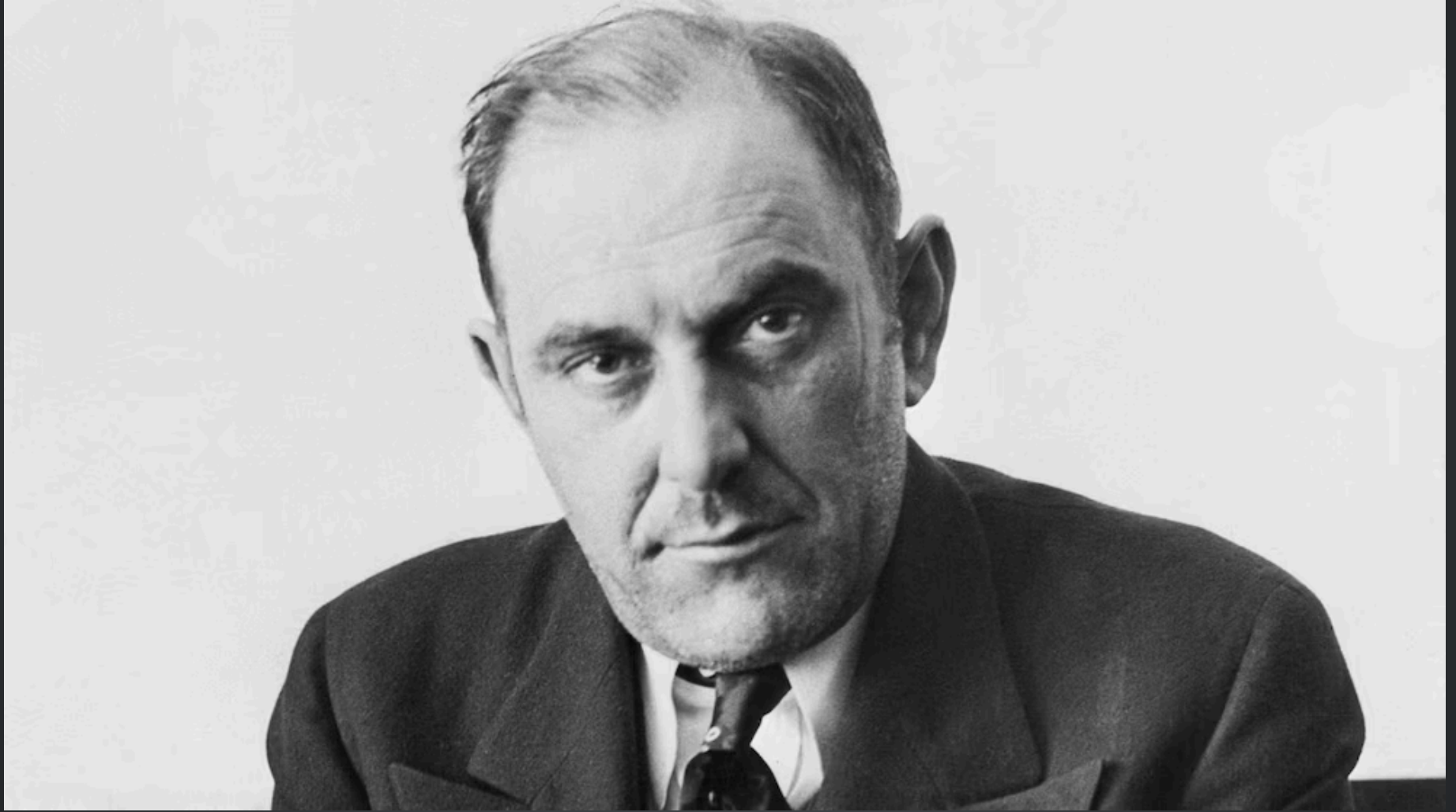
ANÁLISIS: INGENIERÍA SOCIAL



ANÁLISIS: INGENIERÍA SOCIAL

- Cuando los atacantes no pueden acceder al sistema a través de fallas de seguridad, ya sea bugs del software o configuración, utilizan métodos menos técnicos para ganar acceso.
- La **ingeniería social** se define como un conjunto de trucos, engaños o artimañas que permiten confundir a una persona para que entregue información confidencial
- La idea es convencer a los usuarios a que expongan el sistema
- Esto puede realizarse por teléfono, mail (phishing) u otros medios como las redes sociales.
- En la jerga se lo conoce como capa 8

VÍCTOR LUSTIG - SUBASTÓ 2 VECES LA TORRE EIFFEL



ANÁLISIS: EVIDENCIA DIGITAL EN LOS SO

- Cuando empezamos a aplicar nuestros procesos de investigación y métodos de análisis en algún u otro momento tendremos que lidiar con cuestiones específicas de los Sistemas Operativos.
- Es fundamental conocer cada SO para entender su funcionamiento básico y así poder analizar la evidencia desde una perspectiva más objetiva.

INTRODUCCIÓN A LA FORENSIA DIGITAL

FASE DE REPORTE

TEMAS

- Redacción del informe
- Tipos de informes
- Estructura básica del informe

REPORTE

- La última etapa del proceso forense es integrar todos los resultados y conclusiones en un informe final, que transmita todas las conclusiones y resultados a los demás de manera clara y concisa.
- Escribir un informe es una de las etapas más importantes del proceso forense, ya que es la única visión que tienen los demás del mismo.

REDACCIÓN DEL INFORME

- Las suposiciones y falta de fundamentos dan como resultado un informe débil.
- Por lo tanto, es importante construir argumentos sólidos, proporcionando todas las pruebas y demostrar que la explicación dada es la más razonable.
- Demostrar claramente cómo y dónde se encontró toda la evidencia ayuda a interpretar el informe y permite que otro examinador competente verifique los resultados.

REDACCIÓN DEL INFORME

- Presentar escenarios alternativos y demostrar por qué son menos razonables y menos consistentes respecto a la evidencia hallada, puede ayudar a fortalecer las principales conclusiones.
- Explicar lo poco probable o imposible de otras explicaciones respecto a lo ocurrido, demuestra que el método científico ha sido aplicado correctamente.
- Si la evidencia digital se ha alterado después de la recolección es importante mencionar esto en el informe, explicando la causa de las alteraciones y su impacto en el caso.

TIPOS DE INFORMES

- Hay que tener en cuenta que muchas veces los informes van a ser leídos por personas sin conocimientos técnicos.
- El informe en el sector privado puede ser de dos clases: **ejecutivo y técnico**.
 - **Ejecutivo** es un informe enfocado a personas sin conocimientos técnicos
 - **Técnico** explica de una manera técnicamente detallada el procedimiento del análisis.
- El informe en el sector público se denomina: **dictamen pericial**.

INFORME EJECUTIVO

- Los principales lectores de los informes ejecutivos son la alta dirección de las empresas, organismos, etc.; es decir, personas que no tienen un perfil técnico.
- Por lo tanto el informe no debe ser detallado, sino que debe tratarse de un resumen que introduzca al lector a la temática y que abarque todo el proceso y sus conclusiones.
- Los informes de este tipo se caracterizan por tener muchas imágenes, como gráficos y estadísticas, que ayudan al lector a comprender el reporte. Puede incluir recomendaciones.

INFORME TÉCNICO

- Los principales lectores de este tipo de informe son personas con un perfil técnico (informáticos, ingenieros, técnicos superiores, etc.)
- Los informes técnicos son muy detallados y robustos.
- Contienen gran cantidad de información explicando cada uno de los pasos del proceso forense y sus conclusiones.
- Junto a una detallada sección de suposiciones, hipótesis y conclusiones.

ESTRUCTURA BÁSICA

- **Introducción:** número de caso, quién solicitó el informe, quien escribió el informe, cuándo y qué se ha encontrado.
- **Resumen de evidencia:** listar las evidencias, como fue extraída, como y cuando fue examinada , valores de hash, números de envío de laboratorio, cadenas de custodia, cuándo y dónde se obtuvo la evidencia, su condición (signos de daño o alteración).
- **Resumen del análisis:** resumir las herramientas utilizadas para realizar el análisis y cómo se recuperaron los datos importantes (por ejemplo, el descifrado o datos borrados que fueron recuperados).

ESTRUCTURA BÁSICA

- **Análisis del sistema de archivos:** inventario de los archivos importantes y directorios recuperados. Los datos que son relevantes para la investigación con características importantes, tales como nombres de ruta, timestamps, los valores de hash, y la ubicación de sector físico en el disco. Además de notar cualquier ausencia inusual de datos.
- **Análisis:** describir el análisis temporal, funcional, relacional y otros análisis realizados.
- **Conclusiones:** resumen de las conclusiones debe seguir lógicamente las secciones anteriores del informe y debe hacer referencia a elementos de prueba.
- **Glosario de términos:** Las explicaciones de los términos técnicos utilizados en el informe.

ESTRUCTURA BÁSICA

- No hay una única estructura para realizar este tipo de informes, sobre todo al tratarse de un informe para una entidad privada o un cliente particular.
- Una buena práctica es no entregar solo un informe técnico, sino también uno ejecutivo que resuma de la mejor forma posible los hallazgos en un lenguaje apropiado para que lo entienda cualquier persona con los conocimientos mínimos e indispensables sobre informática.

CUIDADO CON LO QUE ESCRIBEN

- Deben saber que, **no importa** cómo inicie un pedido de análisis en forensia digital, si les piden una simple ayuda por un supuesto empleado que cometió algún error usando un sistema, si les piden averiguar e informar por qué un equipo dejó de funcionar, etc, siempre existe la posibilidad de que el cliente decida tomar acciones legales contra otra persona y que la justicia investigue lo que se encuentra enmarcado en un delito.
- De esta forma, es muy probable que su informe sea aportado como evidencia en una denuncia. Esto desencadena un proceso judicial y a futuro, puede que lo que hayan escrito deba ser evaluado por peritos en la materia. Si es controversial, hasta podrían ser citados a declarar (lo vamos a ver en la clase sobre pericias).

DICTAMEN PERICIAL

- Es sumamente importante limitarse a lo que preguntan
- No hacer cosas para lo que su formación no los habilita como idoneos

AL TERMINAR LA CURSADA...

- Van a tener que realizar presentaciones y exponer el caso. Pueden pensarlo como un ensayo de informe, el cual va a ser evaluado (y discutido, por qué no?) por los ojos expertos de sus compañeros!